

# Adding Value With Risk-Based Information Security

Disponibile anche in italiano  
[www.isaca.org/currentissue](http://www.isaca.org/currentissue)

Effective IT security management system design must start with top management and include the entire perimeter of the supply chain, with special attention paid to ensuring compliance with all relevant laws. Adherence to international best practices must form the backbone of the system. Considering the most widespread methodologies (e.g., International Organization for Standardization [ISO] standards, US National Institute of Standards and Technology [NIST] frameworks), it is easy to see that they are all risk-based—that is, decisions are guided exclusively by their effectiveness in counteracting risk.<sup>1</sup>

Using multiple methodologies at the same time represents an advantage in terms of greater completeness (i.e., wider coverage of the control environment) and accuracy (i.e., different levels of detail available) of control, but it can lead to an ineffective and complex process due to the risk of overlapping activities and the use of additional resources. The idea is not wrong—it is just that complementary and integrative methodologies need to be identified, both among themselves and with respect to all the business processes involved.

One possible approach is to integrate the risk management process with the information security management system (ISMS) based on the ISO/International Electrotechnical Commission (IEC) 27001:2022<sup>2</sup> standard and in accordance with the NIST Cybersecurity Framework (CSF) 2.0.<sup>3</sup> Both risk management and ISMS involve processes that perform distinct tasks and are easily integrated. Furthermore, on a methodological level, this approach aims to achieve optimal integration with business processes.

## Risk Management System

The enterprise risk management system (ERMS) plays a fundamental role compared to the IT security

management system. It is the glue between IT operations and business processes and is essential to understanding the value the organization assigns to the information processed. The link is defined by the coincidence of organizational assets, assessed by the risk management process, with IT assets, managed by the IT function. To initiate the development of an ERMS process, it is necessary to establish the business value of all the assets critical to achieving the organization's objectives. These assets are also known as organizational assets. In the case of IT risk management, it means accurately classifying all the means and methods of processing information that are relevant to organizational assets and reviewing this classification cyclically to avoid losing adherence to the objectives. Identifying and assessing risk is the basis for developing and controlling the ISMS.

The work of identifying the IT assets to be protected is carried out in the creation of the organizational asset registry of the ERMS. The advantage, in addition to avoiding the duplication of data collection work for the ISMS, is ensuring that the identified assets are truly vital components of the business objectives and are not derived from a purely technological rationale within the IT department.

**LUIGI SBIRIZ** | CISM, CRISC, CDPSE, ISO/IEC 27001 LA, TISAX AL3, ITIL V4, NIST CSF, UNI 11697:2017 DPO

Is a lead auditor, trainer, and senior consultant on risk management, cybersecurity, and privacy issues and has been the risk monitoring manager at a multinational automotive company for more than seven years. Previously, he was head of ICT's operations and resources in the APAC region (China, Japan, and Malaysia) after serving as worldwide information security officer for more than seven years. He developed an original methodology for internal risk monitoring, merging an operational risk analysis with a consequent risk assessment driven by the maturity level of the controls. He also designed a cyber monitoring tool based on OSINT as well as an integrated system involving risk monitoring, maturity model, and internal audit. Sbriz was a consultant for business intelligence systems for several years. He can be contacted on LinkedIn (<https://www.linkedin.com/in/luigisbriz>).



Methodologically, the components identified by the risk management process with a holistic approach are made available to all stakeholders, both as assets to protect and as actions to implement, through the risk treatment plan (RTP). The focus of the ISMS will be the protection of both the means of processing information and the information itself identified by the RTP. Operationally, it is necessary to develop a congruent set of organizational procedures to guarantee valid collaboration between the two processes, risk and information security, and the attribution of the consequent responsibilities.



#### LOOKING FOR MORE?

- Read *Cybersecurity Audit Program: Based on the NIST Cybersecurity Framework 2.0*: <https://www.isaca.org/nist-csf-audit-program>
- Learn more about, discuss, and collaborate on risk and cybersecurity in ISACA's Online Forums. <https://engage.isaca.org/onlineforums>

## Information Security Management System

The most widespread standard for implementing and verifying an information security management system is presumably ISO/IEC 27001:2022. Among its clauses are the obligation to align the design of the ISMS to the risk process (clause 6) and the consequent evaluation of the corresponding controls implemented (clause 8). Its peculiarity is that it is a model for the creation of a holistic information protection system that is in perfect harmony with the logic of risk management processes. In the current version, there is a propensity to consider all aspects of interest in information security, including cybersecurity and privacy. The topics covered by the standard in the control field also include the Internet of Things (IoT), smart meters, cloud services, and industrial control systems—that is, operational technology.

The level of definition of the controls proposed by the standard is general enough to require a dedicated tool, the statement of applicability (SoA), to ensure that the depth of the control topics is adequate for

meeting the specific objectives of each business category. The drafting of the SoA derives from the analysis of the archive of organizational assets (made available through the risk process) which establishes all the elements to be protected, the level of protection to be assigned to each of them, and the related implementation responsibilities.

The protection system based on ISO/IEC 27001:2022 is made up of two parts: the requirements of the standard to define the management rules of the protection system and the controls of the SoA built on those proposed by ISO/IEC 27002: 2022 (but redefined to suit business objectives). Both the level of implementation of the requirements and the level of effectiveness of the controls require timely evaluation, which can be performed using a maturity model. In this way, the results are always comparable, even if they reflect different processes.

## Cybersecurity Risk Profile

New features introduced in the NIST Cybersecurity Framework (CSF) 2.0 improve its applicability in assessing an organization's cybersecurity risk profile. As a founding intent, it states that "the NIST Cybersecurity Framework helps businesses of all sizes better understand, manage, and reduce their cybersecurity risk and protect their networks and data. The Framework is voluntary."<sup>4</sup> The introduction of the govern function allows an organization to define its governance structure, establish priorities, and set rules to obtain the desired results described through the other five functions, finally detailing them in the relevant categories and subcategories.

The checklist underlying the methodology comprises statements regarding the expected results to achieve for alignment with the established risk profile. The framework does not detail the individual operations that must be carried out or even ways to implement them. It provides an organizational vision of the enterprise processes, the results of which are grouped into functions and categories to give a sense of simplicity and clarity to the whole, achieved precisely by avoiding technical details. This implies the need to consider other methods for the effective implementation of the security management system.

The connection with the methodologies that support the implementation of the protection system appears in the fifth column of the framework (**figure 1**),

dedicated to references to other international models including ISO 27001. This enables a solid link between frameworks, in a simple way and without any ambiguity. The subcategory level assessment of the NIST CSF checklist serves to establish an acceptable cybersecurity risk profile to guide the organization to confidently achieve security objectives. The result of each subcategory is determined by the degree of implementation of the set of one or more controls defined in the RTP for that purpose. Knowledge of the current cyber risk profile compared with the target identifies the actions (controls) necessary to improve the resilience of not only the organization, but also the entities involved in its supply chain.

To facilitate the exchange and consistency of the results of analyses and evaluations carried out with the ISO 27001 standard, the NIST CSF framework, and the requirements set out in the RTP, it is advisable to adopt the same metrics. The maturity model has the best features for this purpose.

### Capability Maturity Model

The vulnerability assessment is directly dependent on the level of implementation of rules, controls, or activities and is the necessary basis for establishing the actions necessary to treat the risk. Each organization has very different areas to evaluate, which concern countless aspects, from organizational to technological. Each must also consider legal, reputational, financial, human, environmental, and physical issues, with security being the only objective

To enhance overall understanding of the state of information protection, it is necessary to have an integrated system for sharing assessments that is coherent and efficient and therefore avoids overlaps in assessment tasks or management complexity.

they have in common. To share the evaluations between all areas, it is necessary to use practical and suitable metrics to carry out the assessments. The choice necessarily leans toward qualitative methods, which are simpler and faster to apply as well as lower cost. Among them, the most widespread is the Capability Maturity Model, which allows the level of effectiveness of controls and the desired risk results to be determined, as required by the RTP.

The maturity model applies equally across all frameworks to integrate the assessment of compliance with ISO standard clauses, the degree of implementation of SoA controls, the state of achievement of NIST CSF function deliverables, and the effectiveness of RTP controls. The result is the production of exhaustive views of the effectiveness of controls and processes, as well as of the cybersecurity risk, according to various perspectives updated over time.

FIGURE 1  
CSF 2.0 Informative Reference in the Core

| <div><div><div><div>GOVERN</div><div>IDENTIFY</div><div>PROTECT</div><div>DETECT</div><div>RESPOND</div><div>RECOVER</div></div><div><div>NIST</div><div>Community Framework</div></div></div><div><div>NIST</div><div>The NIST Cybersecurity Framework 2.0</div><div><a href="https://www.nist.gov/cyberframework">www.nist.gov/cyberframework</a></div></div><div><div>NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY</div><div>U.S. DEPARTMENT OF COMMERCE</div></div></div> |                                                                                                                                                                                                                                                  |                                                                                                                                                                                              |                         |                                                                                                                                                                                     |
|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Function                                                                                                                                                                                                                                                                                                                                                                                                                                                                        | Category                                                                                                                                                                                                                                         | Subcategory                                                                                                                                                                                  | Implementation Examples | Informative References                                                                                                                                                              |
| GOVERN (GV): The organization's cybersecurity risk management strategy, expectations, and policy are established, communicated, and monitored                                                                                                                                                                                                                                                                                                                                   |                                                                                                                                                                                                                                                  |                                                                                                                                                                                              |                         | CRI Profile v2.0: GV<br>CSF v1.1: ID.GV<br>SP 800-221A: GV.PO                                                                                                                       |
|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 | Organizational Context (GV.OC): The circumstances - mission, stakeholder expectations, dependencies, and legal, regulatory, and contractual requirements - surrounding the organization's cybersecurity risk management decisions are understood |                                                                                                                                                                                              |                         | CRI Profile v2.0: GV.OC<br>CSF v1.1: ID.BE<br>SP 800-221A: GV.CT<br>SP 800-221A: GV.CT-5                                                                                            |
|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 | GV.OC-01: The organizational mission is understood and informs cybersecurity risk management                                                                                                                                                     | Ext: Share the organization's mission (e.g., through vision and mission statements, marketing, and service strategies) to provide a basis for identifying risks that may impede that mission |                         | CRI Profile v2.0: GV.OC-01<br>CRI Profile v2.0: GV.OC-01.01<br>CSF v1.1: ID.BE-2<br>CSF v1.1: ID.BE-3<br>SP 800-221A: GV.CT-5<br>SP 800-221A: GV.CT-3<br>SP 800-53 Rev 5.1.1: PM-11 |

Source: National Institute of Standards and Technology, The NIST Cybersecurity Framework (CSF) 2.0, USA, 2024, <https://www.nist.gov/informative-references>

Control Tasks

To enhance overall understanding of the state of information protection, it is necessary to have an integrated system for sharing assessments that is coherent and efficient and therefore avoids overlaps in assessment tasks or management complexity. The integration must be not only functional with the business processes (therefore only a data collection interface) but also operational with the primary processes of the system (therefore sharing the evaluation parameters and calculation methods). Processes should draw upon, at minimum, the ISO 27001 standard, focused on the implementation and control of the operation of the ISMS; the NIST CSF dedicated to determining the risk profile with respect to the expected protection; and the IT risk process aimed at the evaluation of processes, systems, and services to ensure the achievement of enterprise information security objectives.

At an operational level, it would be complex and expensive to implement all the controls required by the various frameworks or standards adopted. However, each control could be obtained from the combination of simple actions available among those already implemented within the organization's processes. Due to the control function that these actions would perform, they could be referred to as control tasks. Furthermore, there must be a central catalog (e.g., **figure 2**) of all control tasks that can be referenced at the level of the individual element of a framework. This idea of equivalence of control capabilities between elements of different frameworks is the same as the basis of the CSF informative references. Control tasks in the catalog are characterized by a narrative of the desired target (compliant with the RTP), a target maturity level, information about the organization, and the list of associated framework elements.

When evaluating a control task (**figure 3**), the current state of implementation of the action and the level of maturity achieved (reported in the RTP) must be

described. The evaluation, when performed via a framework, is automatically shared and the metrics of all the other frameworks are updated accordingly. Additional attributes are recommended to facilitate operational management—such as the role of the control owner or the severity of the action.

Control tasks are linked to frameworks via the lowest level of the respective checklist in the following circumstances:

- The RTP contains a final summary of the current state of risk and the action plan for the desired one. It contains both the controls already implemented as a consequence of the previous assessment cycle, as well as the future actions necessary to make the current level of risk acceptable. The control task is present with the description of the current state (list of current actions), the description of the target result (list of future actions), and the evaluation of the level of maturity reached by the current actions, which represents the measure of vulnerability to the risk event.
- ISO 27001 includes the requirements of the standard clauses and the controls that make up the SoA. Both require actions to provide evidence of the level of maturity achieved in the implementation, and this coincides with the description of the current state of the control tasks. To be consistent with risk assessments, evidence is drawn from the list of current stocks included in the RTP. Therefore, it is required to evaluate not only the controls of the SoA, but also the clauses of the standard, combining each element with the appropriate actions implemented to combat the risk.
- The NIST CSF sets subcategories as the evaluation level, which, although detailed, are still too generic and synthetic to accurately describe the various actions implemented. Instead, the control tasks provide adequate detail to the evaluation needs through current actions, as set out in the RTP.

FIGURE 2  
Control Tasks Catalog

| Control tasks catalogue                                                                                   |            |                                          |                                                                                                                                                                                                          |           |                           |                               |
|-----------------------------------------------------------------------------------------------------------|------------|------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|---------------------------|-------------------------------|
| Task UID                                                                                                  | Capability | Task name                                | Target task                                                                                                                                                                                              | Maturity  | Process                   | Owner                         |
| ▼ DIR.01                                                                                                  | Governance | Share the organization's mission         | Share the organization's mission (e.g., through vision and mission statements, marketing, and service strategies) to provide a basis for identifying risks that may impede that mission                  | Compliant | Directorate (DIR)         | Chief Executive Officer (CEO) |
| Frameworks: ISO/IEC 27001:2022 Statement of Applicability NIST Cybersecurity Framework 2.0                |            |                                          |                                                                                                                                                                                                          |           |                           |                               |
| 9.1 Evaluate I S performance A.5.1 Policies for information security GV.DC-01 Organizational Context - 01 |            |                                          |                                                                                                                                                                                                          |           |                           |                               |
| 9.2.1 Conduct internal audit                                                                              |            |                                          |                                                                                                                                                                                                          |           |                           |                               |
| 9.2.2 Implement audit programme                                                                           |            |                                          |                                                                                                                                                                                                          |           |                           |                               |
| 9.3.1 Review organization's ISMS                                                                          |            |                                          |                                                                                                                                                                                                          |           |                           |                               |
| ► GRC.01                                                                                                  | Governance | Identify relevant internal stakeholders. | Identify relevant internal stakeholders and their cybersecurity-related expectations (e.g., performance and risk expectations of officers, directors, and advisors; cultural expectations of employees). | Compliant | Risk and Compliance (GRC) | Risk Manager (RISK)           |

**FIGURE 3**  
NIST CSF Assessment via Control Tasks

| NIST Cybersecurity Framework 2.0                                                                                                                                                                                                        |                                                                                                                                                                                                                            |           |                       |          |                         |
|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------|-----------------------|----------|-------------------------|
| Code                                                                                                                                                                                                                                    | Description                                                                                                                                                                                                                | Maturity  | Category owner        | Note     |                         |
| GV                                                                                                                                                                                                                                      | Govern: Establish and monitor the organization's cybersecurity risk management strategy, expectations, and policy                                                                                                          |           |                       |          |                         |
| GV.OC                                                                                                                                                                                                                                   | Organizational Context: The circumstances - mission, stakeholder expectations, and legal, regulatory, and contractual requirements - surrounding the organization's cybersecurity risk management decisions are understood |           |                       |          |                         |
| GV.OC-01                                                                                                                                                                                                                                | The organizational mission is understood and informs cybersecurity risk management                                                                                                                                         | Improving | Chief InfoSec Officer |          |                         |
| Task UID                                                                                                                                                                                                                                | Current task                                                                                                                                                                                                               | Maturity  | Progress              | Due date | Control owner           |
| DIR.01                                                                                                                                                                                                                                  | Evaluation of the current state.                                                                                                                                                                                           | Compliant | Unknown               | ...      | Chief Executive Officer |
| Target task: Share the organization's mission: Share the organization's mission (e.g., through vision and mission statements, marketing, and service strategies) to provide a basis for identifying risks that may impede that mission. |                                                                                                                                                                                                                            |           |                       |          |                         |

The idea, therefore, is to identify appropriate actions at the RTP level and evaluate them in the risk process. All the actions are then combined with the standards and frameworks, with the possibility of a further evaluation directly on the checklists, if necessary, and automatic sharing of the result with the risk process, which maintains the role of the container of the implemented control tasks. In this way, the advantage is a simplification of the evaluation process, because redundancies are avoided and quality is improved due to the homogeneity between the various checklists. In case there are difficulties in identifying the actions, a good starting point is to review the examples of implementing subcategories through actions in the NIST CSF 2.0 concept paper,<sup>5</sup> adapting them to the characteristics of the specific organization. Additionally, these action examples are easily matched to SoA controls via references in the NIST CSF.

## Operational Notes on ISMS Design

To understand how to implement a protection system integrated with the risk process, some operational considerations are needed. A centralized tool capable of managing all implemented control activities (i.e., control tasks) must be used to share them between the protection system, the RTP, and any other control framework adopted. The tool manages the relationships between the elements of the frameworks and implements the process of automatic aggregation of the assessments carried out by the control owners. Depending on the complexity and size of the enterprise, it may be necessary to divide it into various organizational units (entities) to focus on critical processes, each evaluated individually and then automatically aggregated to the top of the organization. The process of creating fictitious entities does not introduce any additional effort because it is performed automatically by the system, but a clear

organization is still required to establish the roles and responsibilities useful for guaranteeing the constant monitoring of controls.

At the design level of the overall system, it is necessary to guarantee adequate flexibility in managing the relationships between the control elements implemented and those required by the framework. This helps avoid unnecessary redundancies and provides the system with workflows for an effective division of update tasks.

The following functional rules for database design should be followed:

- There is only one organizational asset archive and it is managed by the ERMS process ensuring two hierarchical levels of assets. Primary (or organizational) assets originate directly from enterprise objectives and are managed only by the ERMS. Secondary assets are significant components of primary assets, capable of causing operational critical issues (e.g., IT risk) for business processes.
- The archive of control tasks is unique and common among all the checklists used. The assessments of the current state and level of maturity are the responsibility of the relevant business owners, while the target state can only be modified during the definition of the RTP.
- The RTP is defined starting from the asset archive and the identified threat categories are added for each asset. In this way, each record represents a risk event to be treated while the existing and desired controls are directly linked to the control tasks archive.
- The ISO 27001 clause checklist is related to the control tasks archive to allow for the assessment of the level of maturity of the current state of implementation of the relevant requirements.

Both frameworks are based on the concepts of risk management and cyclical improvement, that is, not waiting to reach optimal status to start, but rather starting with a solution that is continuously refined by counteracting the risk. In doing so, the solution can adapt to all the changes in the digital ecosystem.

Current actions can be further evaluated (in addition to the RTP) in this checklist, and results can be shared across all frameworks.

- The checklist with the controls defined by the SoA is related to the archive of control tasks to allow for assessments of the maturity achieved in the implementation of the relevant controls. Also, for this checklist, it is possible to evaluate current actions and share the results.

- The NIST CSF checklist has subcategories related to SoA controls as referenced by NIST, but also in relation to the control task repository to allow the use and possible evaluation of current actions. The set of results aggregated by subcategory represents the cybersecurity profile.

The assessments are carried out by the control owners of the business processes for each entity, which means distributing the activity across a large set of subjects to reduce the burden of effort on the individual. The supervision of the evaluation processes, to aggregate the results up to the executive level, is done under the supervision of risk management for the RTP, while the chief information security officer (CISO) is responsible for the ISO 27001 and NIST CSF security checklists.

### ISMS Quality

Integrating the ISMS, implemented according to the ISO 27001 standard, with the cyberrisk profile evaluation framework based on the NIST CSF generates a more effective ISMS, as it is

**FIGURE 4**  
ISMS Principles of Quality

| Principle                             | Description                                                                                                                                                                                                                                                                                                                                                   |
|---------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1. Focus on Security                  | Ensuring information security is a transversal purpose across all processes to satisfy operational continuity and enterprise objectives. The reduction in the number of incidents and the containment of the impact consequently benefits the performance of the entire organization.                                                                         |
| 2. Leadership                         | The purpose of the system governance process is well-defined in two areas: the definition of a security organization aligned with business objectives and the constant verification by management of the correct functioning of the system.                                                                                                                   |
| 3. Commitment of People               | The contributions of individuals involved in the system are highlighted in both frameworks, which consider skills and awareness of the consequences of acting outside the rules. Corrective measures based on training plans and behavioral policies are also addressed.                                                                                      |
| 4. A Process-Oriented Approach        | The security management system is based on a process-structured approach, as is the cybersecurity framework and the risk process itself. For the actions and interactions of processes and subprocesses, internal or external, complete documentation and careful measurement of performance are always required.                                             |
| 5. Improvement                        | The system requirements at a methodological level provide for the alignment of the system results with the organizational objectives, directing research toward adequate solutions to achieve those objectives, and continuous monitoring of activities to establish the effectiveness of the controls in order to pursue continuous performance improvement. |
| 6. Risk-Based Decision-Making Process | Both the standard and the framework help facilitate effective and efficient decisions throughout the process because they derive from assessments linked to organizational objectives and the factors that can lead to uncertainty about their achievement.                                                                                                   |
| 7. Relationship Management            | A focal point of the system is the strong attention paid to sharing the most significant security issues with all interested parties in the supply chain, whether internal or external, both in the threat collection phases and in the declaration of security incidents.                                                                                    |

strengthened from a risk management perspective. Both frameworks are based on the concepts of risk management and cyclical improvement, that is, not waiting to reach optimal status to start, but rather starting with a solution that is continuously refined by counteracting the risk. In doing so, the solution can adapt to all the changes in the digital ecosystem.

Thinking about the principles on which a quality management system is based (**figure 4**), in particular, viewing them through the lens of information security, it is clear that the ISMS must respect them all to be effective. The use of metrics derived from the principles allows one to determine their level of maturity, which provides an additional method of evaluating the functionality of the ISMS.

## Conclusion

The ISO standard for information security and the NIST framework for cybersecurity should always coexist together—not because they are simple to derive from each other, but because they are complementary and represent two sides of the same coin. Methodologically they have various points of overlap. Both push for an integrated approach with business processes and require a decision-making phase constantly guided by risk assessment. In the standard, it is required to implement risk management in order to obtain effective guidance for operational processes. In the framework, risk is used to define the overall profile of the cybersecurity state and to evaluate the gap to achieve the desired result.

The use of a maturity model in control evaluations allows for speed of execution and aggregation of results even if they are derived from areas lacking operational affinities, such as organizational issues compared to technological ones. When the results of the current risk state must be consolidated to expose them to top management, the advantage provided by the ease of collecting and presenting the results is evident, operating on an adequate, common, and

homogeneous evaluation basis (the control tasks). Highlighting the issues relevant to the organization promptly and with the right language facilitates communication and helps consolidate the trust of all stakeholders—that is, it brings value.

## Endnotes

- 1 National Institute of Standards and Technology (NIST), NIST Special Publication (SP) 800-37r2 *Risk Management Framework for Information Systems and Organizations*, USA, 2018, <https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-37r2.pdf>; International Organization for Standardization, ISO 31000—*Risk management*, 2018, <https://www.iso.org/standard/65694.html>; National Institute of Standards and Technology, NIST SP 800-30r1 *Guide for Conducting Risk Assessments*, USA, 2012, <https://nvlpubs.nist.gov/nistpubs/legacy/sp/nistspecialpublication800-30r1.pdf>; ISACA®, *CRISC Review Manual*, 7<sup>th</sup> Edition Revised, 2023, <https://store.isaca.org/s/store#/store/browse/detail/a2S4w000004Tx3aEAC>
- 2 International Organization for Standardization, ISO 27001—*Information security*, 2018, <https://www.iso.org/standard/65694.html>
- 3 National Institute of Standards and Technology, *Cybersecurity Framework CSF 2.0 Reference Tool*, Subcategory ID.RA-05, USA, <https://csrc.nist.gov/Projects/cybersecurity-framework/Filter/#/csf/filters>
- 4 Federal Trade Commission, *Understanding the NIST Cybersecurity Framework*, USA, <https://www.ftc.gov/business-guidance/small-businesses/cybersecurity/nist-framework>
- 5 National Institute of Standards and Technology, NIST Cybersecurity Framework 2.0 Concept Paper: *Potential Significant Updates to the Cybersecurity Framework*, USA, 2023, [https://www.nist.gov/system/files/documents/2023/01/19/CSF\\_2.0\\_Concept\\_Paper\\_01-18-23.pdf](https://www.nist.gov/system/files/documents/2023/01/19/CSF_2.0_Concept_Paper_01-18-23.pdf)

## Train Your Way—and Advance Your Career

At ISACA, our wide range of online course options, coupled with around-the-clock access to course materials, gives you the flexibility to grow your knowledge and skills in a way that fits your schedule—and career goals. Go to **[www.isaca.org/training](https://www.isaca.org/training)**.

